PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Architecture du système de journalisation

03-1050 ANSSI - Recommandations de sécurité pour l'architecture d'un système de journalisation — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La production des journaux doit s'appuyer sur des solutions avec fonction native activées sur un grand nombre d'équipements.
2. Le transfert des journaux doit privilégier le temps réel ou être automatisé avec un délai ne dépassant pas quelques heures.
3. Les serveurs de collecte doivent être durcis et cloisonnés dans un SI d'administration ou une zone dédiée.

Historique du guide

décembre 2013
première version

28 janvier 2022
version 2.0

31
nombre de recommandations

Périmètre du guide

- Le guide décrit l'architecture d'un système de journalisation couvrant : la **production des évènements**, la **collecte**, le **transfert**, le **stockage**, la **protection** et le cas de l'**externalisation**.

Principes de production des journaux

Notion	À retenir
Activer la journalisation	Utiliser des solutions avec **fonction native** et activer la journalisation sur un **nombre important d'équipements**.
Horodater et synchroniser	Horodatage homogène, horloges **synchronisées** sur des sources cohérentes ; de préférence heure **UTC** et format **ISO 8601**.
Choisir ce que l'on journalise	Définir la **granularité** (tout journaliser épuise les ressources) ; journaliser les **empreintes** des fichiers suspects ; estimer l'espace de stockage.

Collecte et transfert des journaux

Notion	À retenir
Centraliser	Centraliser ou exporter vers un autre équipement. Construire un service **résilient**, hiérarchiser les serveurs et contrôler la **couverture**. Conserver le **format natif** avant transfert.
Transférer	Privilégier le **temps réel** ou automatiser sous **quelques heures**. Utiliser des protocoles fiables et sécurisés (**TLS**, **SSH** ou **IPsec**) après analyse de risque et maîtriser le **flux réseau**.

Architecture de stockage et protection

Notion	À retenir
Serveurs de collecte	Les **durcir**, les **maintenir à jour** et les **cloisonner** dans un **SI d'administration** ou une **zone dédiée**.
Le stockage	**Dédier une partition disque** aux journaux, **superviser l'espace**, classer par thématique et utiliser une **base de données indexée** (niveau renforcé). Politique de **rotation**, durées de **rétention** réglementaires, suppression **automatisée** si possible.
Droits d'accès	Appliquer le **moindre privilège** pour restreindre l'**écriture**, la **suppression** et la **lecture** au **strict besoin opérationnel**.

Externalisation et nomadisme

Cas	À retenir
Externalisation	Étudier un ou plusieurs systèmes de journalisation ; récupérer les journaux des **interconnexions** ; recourir à un **PDIS qualifié** pour le stockage ou la corrélation externalisés.
Nomadisme	Collecter les journaux des **postes nomades**.

Pièges et confusions

- ⚠ Croire que les journaux peuvent être corrélés sans horloges synchronisées
- ⚠ Utiliser un transfert différé dépassant quelques heures
- ⚠ Modifier le format des journaux avant leur transfert
- ⚠ Placer les serveurs de collecte en dehors du SI d'administration
- ⚠ Oublier d'automatiser la suppression des journaux après la durée de rétention

Sigles et définitions

Journalisation	enregistrement des évènements sur les équipements et applications sous forme de logs
Évènement de sécurité	trace d'activité utile à la détection ou à l'investigation d'un incident
Horodatage	association d'une date et d'une heure précises à chaque évènement
UTC	temps universel coordonné, référence horaire évitant les passages à l'heure d'été et d'hiver
Rotation des journaux	remplacement périodique des fichiers de journaux pour maîtriser l'espace disque
PDIS	prestataire de détection des incidents de sécurité qualifié par l'ANSSI
SI d'administration	système dédié aux tâches d'administration, isolé du reste du système

Auto-test

1. Combien de recommandations contient le guide ?
2. Quelle norme uniformise le format de représentation des dates et heures ?
3. Quels protocoles sécurisés peuvent être utilisés pour le transfert ?
4. Quel principe appliquer pour restreindre l'écriture, la suppression et la lecture ?
5. Quelle est la version actuelle du guide ?

Réponses : **1.** 31 · **2.** ISO 8601 · **3.** TLS, SSH ou IPsec · **4.** Le moindre privilège · **5.** 2.0

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.